

DETAILED WEB APPLICATION SECURITY ASSESSMENT REPORT

Target Application: OWASP Juice Shop (Local Deployment)

Assessment Type: Vulnerability Assessment & Penetration Testing (VAPT)

Tools Used: OWASP ZAP, Burp Suite (Community Edition)

Prepared By: Security Analyst

Date: 2026

1. Executive Summary

This report documents the results of a detailed security assessment conducted on the OWASP Juice Shop web application. The objective was to identify vulnerabilities that could be exploited by malicious actors to compromise application security. The assessment revealed multiple high and medium severity issues that pose significant risks if deployed in a production environment.

2. Scope of Assessment

The assessment was limited to the publicly accessible functionality of the OWASP Juice Shop application. Testing was performed using a black-box approach without access to source code. Denial-of-service and infrastructure-level attacks were excluded from scope.

3. Methodology

Testing was conducted using industry-standard methodologies aligned with the OWASP Testing Guide. Both automated and manual techniques were employed to identify vulnerabilities, validate findings, and assess real-world exploitability.

Phases:

- Information Gathering
- Automated Vulnerability Scanning
- Manual Exploitation
- Risk Analysis
- Reporting

4. Vulnerability Findings

Vulnerability	Severity	OWASP Mapping	Business Impact
SQL Injection	High	A03: Injection	Complete database compromise
Cross-Site Scripting (XSS)	Medium	A07: XSS	Session hijacking
Broken Authentication	High	A02	Account takeover
Sensitive Data Exposure	Medium	A02	Data leakage
Cross-Site Request Forgery	Medium	A01	Unauthorized actions

4.1 SQL Injection

Severity: High

OWASP Mapping: OWASP A03: Injection

Description: Improper input validation allows attackers to manipulate database queries.

Impact: Attackers can read, modify, or delete sensitive database records.

Remediation: Use parameterized queries, input validation, and ORM frameworks.

4.2 Cross-Site Scripting (XSS)

Severity: Medium

OWASP Mapping: OWASP A07: XSS

Description: Malicious scripts can be injected and executed in victim browsers.

Impact: Session tokens and user credentials may be stolen.

Remediation: Implement output encoding, CSP headers, and input sanitization.

4.3 Broken Authentication

Severity: High

OWASP Mapping: OWASP A02: Authentication Failures

Description: Weak authentication mechanisms allow unauthorized access.

Impact: Attackers may take over legitimate user accounts.

Remediation: Implement strong password policies and multi-factor authentication.

4.4 Sensitive Data Exposure

Severity: Medium

OWASP Mapping: OWASP A02: Cryptographic Failures

Description: Sensitive information is transmitted or stored insecurely.

Impact: User data may be intercepted by attackers.

Remediation: Enforce HTTPS, encrypt data at rest and in transit.

4.5 Cross-Site Request Forgery

Severity: Medium

OWASP Mapping: OWASP A01: Broken Access Control

Description: Lack of CSRF protection allows unauthorized actions.

Impact: Users can be tricked into performing harmful actions.

Remediation: Use CSRF tokens and SameSite cookies.

5. Risk Rating Summary

Severity Level	Description
High	Immediate remediation required
Medium	Fix in next development cycle
Low	Monitor and improve security posture

6. Overall Recommendations

- Integrate security testing into SDLC
- Conduct regular penetration tests
- Apply secure coding standards
- Implement centralized logging and monitoring
- Provide secure coding training to developers

7. Conclusion

The assessment highlights significant security weaknesses within the tested application. Addressing these vulnerabilities will greatly improve the application's resilience against real-world attacks and align it with industry security best practices.